

과제 8 · PASSKEY · PRIVATE SPACE

검증 기록 및 제출 자료

검증 안내서

어디로 가나요

공개 주소: <https://08end.vercel.app/>

무엇을 하나요

1. 공개 소개 페이지를 확인한 뒤 PRIVATE SPACE 가 로그인 전에는 잠겨 있고 비공개 자료가 내려오지 않는지 확인합니다.
2. 패스키를 등록하고 로그인하면서 서버가 매번 새 challenge 를 만들고, 공개키만 저장하며 재사용한 challenge 는 거절하는지 확인합니다.
3. 한 계정에 패스키 2 개를 등록·삭제하고 남은 패스키로 로그인한 뒤, A/B 검증 계정의 비공개 자료가 서로 섞이지 않는지 확인합니다.

무엇이 보이면 통과인가요

공개 소개 페이지는 누구나 볼 수 있고 PRIVATE SPACE 의 실제 자료는 패스키 인증 전에는 내려오지 않아야 합니다. 등록 시 공개키만 서버에 저장되고 로그인마다 새 challenge 가 발급되며, 사용한 challenge 재전송은 거절되어야 합니다. 패스키 2 개 관리와 삭제 후 남은 패스키 로그인, A/B 계정의 양방향 자료 격리까지 확인되면 통과입니다.

안 될 때

현재 선택한 검증 계정과 로그인 상태를 먼저 확인합니다. 패스키 인증이 예상과 다르면 로그아웃 후 다시 시도하고, Network 의 상태 코드·challenge·응답을 확인합니다. 제출 캡처에는 세션값·인증 원문·비밀키를 남기지 않습니다.

AI 3 줄

AI 에게 맡긴 일 WebAuthn·서버 세션·계정 격리 코드 구조를 카드 기준과 대조하고, 검증 순서와 제출 문서의 표·설명·증거 배치를 정리하게 했다.

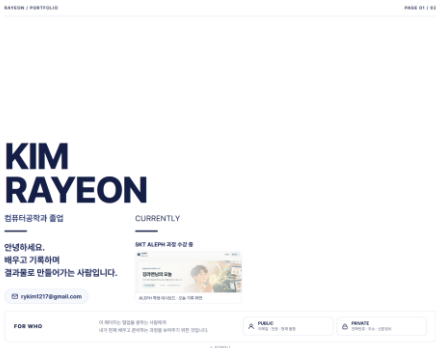
내가 판단한 일 공개/비공개 화면 구성, 실제 등록할 패스키 이름, 삭제할 패스키, A/B 검증 순서와 최종 제출에 사용할 캡처를 직접 확인하고 선택했다.

AI 말을 안 들은 일 특정 기기 방식으로 강제하는 우회 구현은 사용하지 않고 일반 WebAuthn 흐름으로 되돌렸으며, 실제 확인하지 않은 항목은 PASS 로 적지 않았다.

1. 공개 소개와 비공개 영역을 분리하기

검증 항목	확인 내용	결과
공개/비공개 구분	PAGE 01:02 는 공개 소개, PAGE 03 은 PRIVATE SPACE 로 분리	PASS
비공개 항목	PORTFOLIO ARCHIVE · LEARNING LOG · PRIVATE SCHEDULE 3 개 구성	PASS
비로그인 화면	3 개 카드가 LOCKED 이며 실제 저장 자료는 표시하지 않음	PASS
직접 자료 요청	비로그인 GET /api/private 요청은 401 Unauthorized	PASS
서버 데이터	비공개 실제 목록은 t08_private_items 에서 인증 후에만 조회	PASS

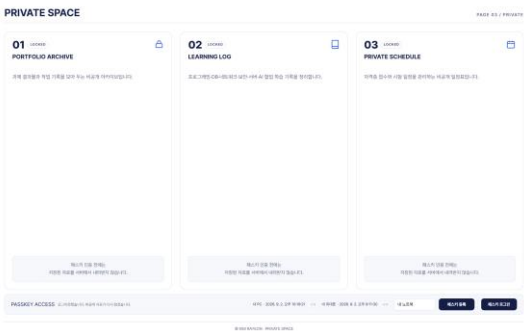
공개 소개 화면은 그대로 유지하고, PAGE 03 의 실제 비공개 목록은 HTML 에 고정하지 않고 서버 DB 에서 인증된 세션 사용자 기준으로만 불러오도록 구성했습니다.



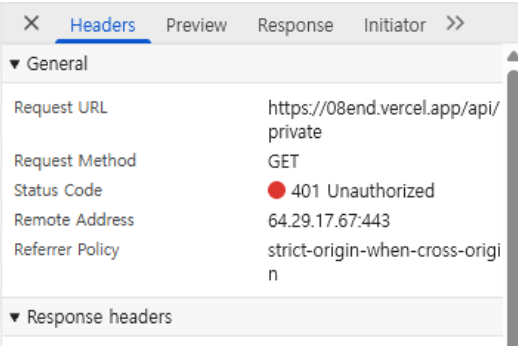
PAGE 01 — 기존 공개 소개 화면 유지



PAGE 02 — 기존 공개 근거 화면 유지



패스키 인증 전 PRIVATE SPACE — 실제 비공개 목록은 LOCKED

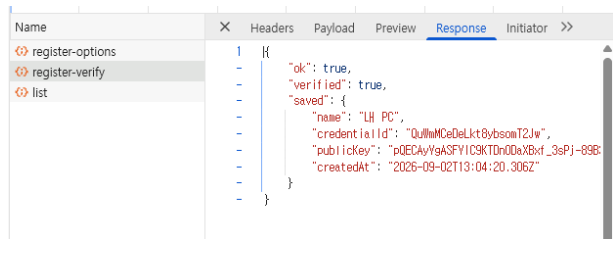


비로그인 /api/private 직접 요청 — 401 Unauthorized

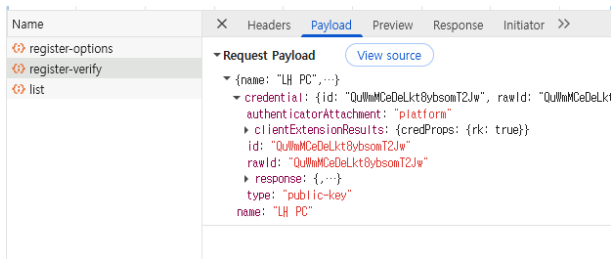
2. 패스키를 등록하고 공개키만 서버에 저장하기

검증 항목	확인 내용	결과
사용 방식	@simplewebauthn/server 13.3.3 + WebAuthn 브라우저 API	PASS
등록 challenge	서버가 등록용 challenge 를 생성해 t08_challenges 에 임시 저장	PASS
challenge 갱신	등록 요청마다 새 challenge 를 발급하도록 구현·확인	PASS
서버 저장값	credential_id · 이름 · public_key · counter 등 저장	PASS
개인키	등록 요청 Payload 에 privateKey 필드가 없고 기기 인증기에 남음	PASS
패스키 이름	내 PC · 내 휴대폰처럼 사람이 알아볼 수 있는 이름 사용	PASS
등록 취소	사용자 취소 시 안내만 표시되고 패스키가 저장되지 않음	PASS

패스키 등록은 비밀번호를 서버에 맡기는 방식이 아닙니다. 기기에서 키 쌍을 만들고 서버에는 검증에 필요한 공개키만 저장합니다. 실제 register-verify 응답에서 publicKey 저장을 확인했고, 요청 Payload 에는 privateKey 가 포함되지 않았습니다.



register-verify 응답 — verified=true, publicKey 와 등록 시각
저장

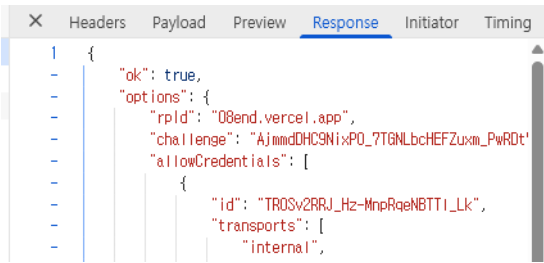


register-verify Payload — public-key credential 만 전송,
privateKey 필드 없음

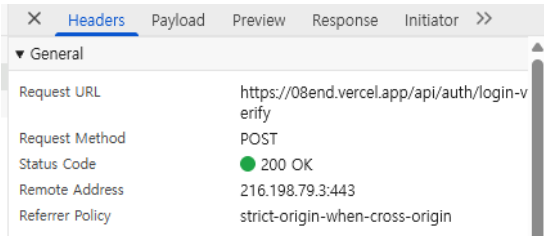
3. 새 challenge 로 로그인하고 재사용을 거절하기

검증 항목	확인 내용	결과
로그인 challenge	로그인 요청마다 서버에서 새 challenge 생성	PASS
challenge 차이	연속 login-options 응답의 challenge 값이 서로 다름	PASS
서명 검증	저장된 공개키로 verifyAuthenticationResponse 수행	PASS
정상 로그인	login-verify POST 200 OK · verified=true	PASS
재사용 차단	성공 요청을 그대로 재전송하면 400 AUTH_CHALLENGE_NOT_FOUND_OR_USED	PASS
세션 유지	t08_session HttpOnly · Secure · SameSite=Lax, 서버에는 SHA-256 해시 저장	PASS
로그아웃	서버 세션과 쿠키를 제거한 뒤 /api/private 접근은 401	PASS
비밀번호	가입·로그인 UI 와 API 에 비밀번호 입력 필드 없음	PASS

인증 challenge 는 t08_challenges 에 일회용으로 저장하고, 알려진 credential 로 검증을 시도한 뒤 삭제합니다. 인증 성공 시 8 시간 서버 세션을 만들며 세션 원문은 DB 에 저장하지 않고 SHA-256 해시만 저장합니다.



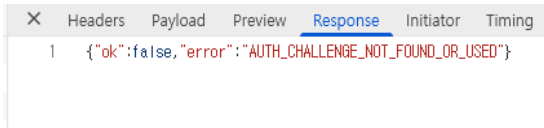
첫 login-options 응답 — challenge 확인



정상 login-verify — POST 200 OK



다시 요청한 login-options — 다른 새 challenge

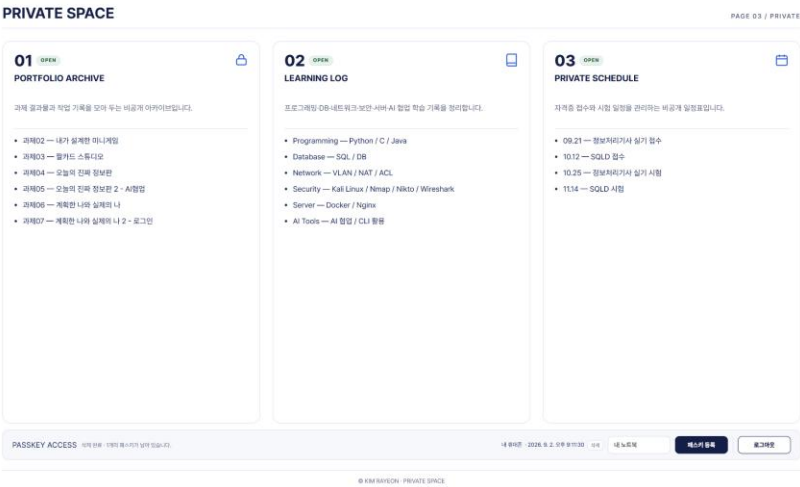


같은 인증 요청 재전송 —
AUTH_CHALLENGE_NOT_FOUND_OR_USED

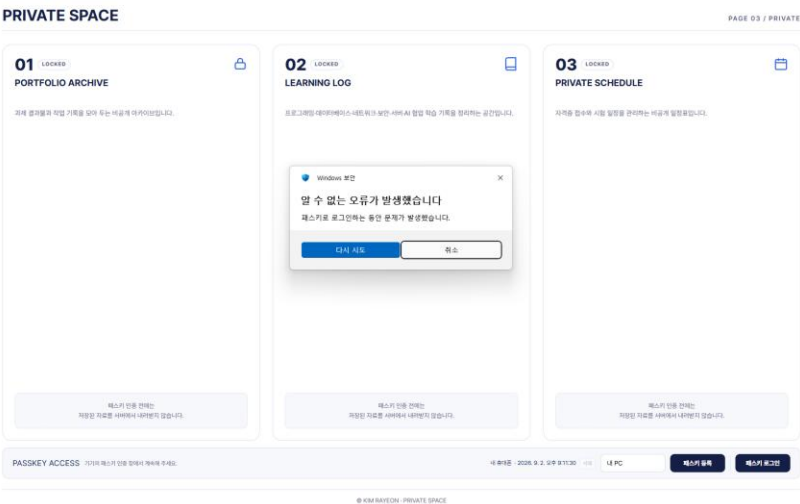
4. 패스키 2 개를 등록하고 하나를 삭제하기

검증 항목	확인 내용	결과
복수 패스키	한 계정에 내 휴대폰 + 내 PC 두 패스키 등록 확인	PASS
목록 표시	패스키 이름과 등록 날짜를 목록에 표시	PASS
삭제	인증된 세션 사용자가 소유한 credential 만 삭제	PASS
삭제 후 상태	내 PC 삭제 뒤 내 휴대폰 1 개가 남았다는 상태 문구 확인	PASS
남은 패스키	삭제 후 남은 휴대폰 패스키로 다시 로그인 성공	PASS
삭제된 패스키	삭제된 PC credential 은 DB/허용 목록에서 제거되어 다시 사용할 수 없음	PASS
0 개 처리	0 개가 되면 새 패스키 등록이 필요하다는 안내를 표시하도록 구현	PASS

패스키 삭제는 로그인된 사용자 소유 credential 만 대상으로 처리합니다. 실제로 PC 패스키를 삭제한 뒤 목록에는 휴대폰 하나만 남았고, 남은 휴대폰 패스키로 다시 인증했습니다. 삭제된 PC 패스키로 시도했을 때는 인증을 계속할 수 없었습니다.



내 PC 삭제 후 — “삭제 완료 · 1 개의 패스키가 남아 있습니다.”



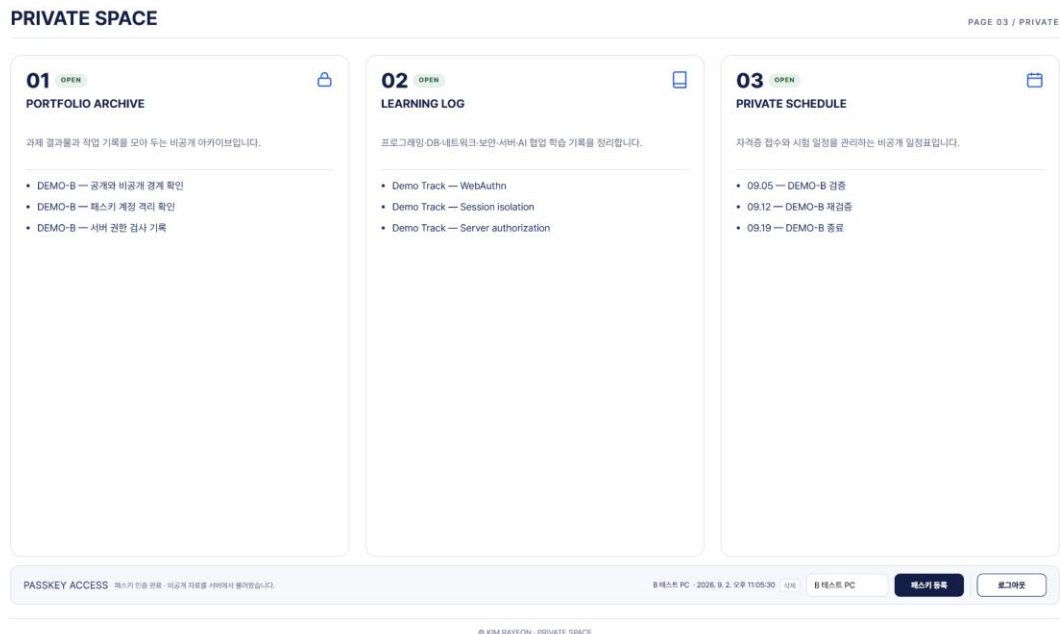
삭제한 PC 패스키로 로그인 시도 — 기기에서 인증을 계속할 수 없음

내 소개 페이지에 패스키 달기 — 비밀번호 없이 나만 들어가기 · 검증 기록

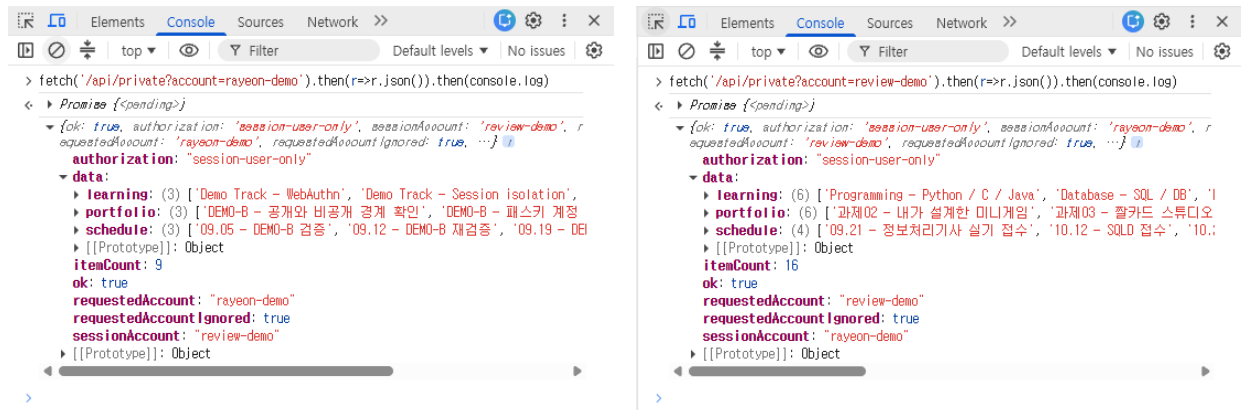
5. 두 검증 계정의 비공개 자료를 서버에서 격리하기

검증 항목	확인 내용	결과
공개 주소	HTTPS https://08end.vercel.app/ · 첫 화면은 공개 소개 페이지	PASS
검증 계정	A rayeon-demo · B review-demo(REVIEW DEMO) 사용	PASS
서로 다른 자료	A 16 개 · B 9 개의 서로 다른 비공개 항목 확인	PASS
B → A 요청	B 세션에서 account=rayeon-demo 를 보내도 B 자료 9 개만 반환	PASS
A → B 요청	A 세션에서 account=review-demo 를 보내도 A 자료 16 개만 반환	PASS
권한 기준	/api/private 는 요청 account 가 아니라 HttpOnly 세션 user_id 로 조회	PASS
검증 데이터	B 는 DEMO-B 로 표시한 합성 데이터만 사용	PASS

계정 격리는 화면의 account 값이 아니라 서버 세션의 user_id 로 결정합니다. /api/private 는 요청으로 다른 account 값을 보내더라도 권한 판단에 사용하지 않고 requestedAccountIgnored=true 로 표시하며, 현재 로그인 세션의 자료만 SELECT 합니다.



B(review-demo) 로그인 — A 와 다른 DEMO-B 비공개 자료 표시



B 세션에서 A ID 요청 — ignored=true, B 자료 9 개 반환

A 세션에서 B ID 요청 — ignored=true, A 자료 16 개 반환

내 소개 페이지에 패스키 달기 — 비밀번호 없이 나만 들어가기 · 검증 기록

6. 패스키 인증 구현 설명

① 무엇으로 붙였나

@simplewebauthn/server 13.3.3 을 사용해 WebAuthn 등록·인증 검증을 구현하고, @neondatabase/serverless 1.1.0 으로 Neon PostgreSQL 에 사용자·challenge·passkey-session·private item 을 저장했습니다. 브라우저에서는 비밀번호 대신 패스키 credential 을 사용합니다.

② 왜 그걸 골랐나

과제의 핵심인 “기기에는 개인키, 서버에는 공개키” 구조와 challenge 기반 서명 검증을 직접 확인할 수 있고, 비밀번호 저장 자체를 없앨 수 있어 WebAuthn 패스키 방식을 선택했습니다.

③ 어디를 어떻게 고쳤나

등록 API 에서 challenge 를 발급·저장하고 검증 성공 시 credential_id 와 public_key 를 저장했습니다. 로그인 API 는 새 challenge 와 저장 공개키로 서명을 검증하고 성공 시 t08_session 서버 세션을 발급합니다. /api/private 는 세션 user_id 로만 비공개 자료를 조회합니다.

④ 안 열리는 것을 확인한 기록

비로그인 /api/private 는 401 로 거절됐고, 사용한 인증 challenge 를 그대로 재전송하면 400 AUTH_CHALLENGE_NOT_FOUND_OR_USED 가 반환됐습니다. A/B 계정에서는 상대 account ID 를 보내도 요청값이 무시되고 현재 세션 자료만 반환되는 것을 양방향으로 확인했습니다.

⑤ AI 와 나

AI 에게는 WebAuthn 코드 구조와 카드별 요구사항 대조, 검증 순서와 문서 구성을 맡겼습니다. 실제 패스키 등록·삭제·로그인, challenge 재사용, A/B 격리 요청은 직접 수행했고 제출에 사용할 화면도 직접 확인했습니다.

⑥ 아직 못 막은 것

검증용 A/B 계정 선택은 과제 확인을 위해 URL query 로 구분할 수 있게 두었습니다. 다만 비공개 자료 권한은 이 값에 의존하지 않고 HttpOnly 세션 user_id 로 강제합니다. 실제 서비스라면 별도의 정식 계정 생성·복구 절차와 패스키 분실 대응 정책을 추가해야 합니다.

확인 4 줄

- ① 공개 소개는 그대로 열고 PRIVATE SPACE 의 실제 자료는 패스키 인증 전에는 내려오지 않습니다.
- ② 패스키 등록 시 서버에는 공개키만 저장되고, 로그인할 때마다 새 challenge 를 사용합니다.
- ③ 사용한 challenge 재전송은 거절되며 로그아웃 뒤 비공개 자료 요청도 401 로 차단됩니다.
- ④ 한 계정의 패스키 2 개 관리와 A/B 계정 양방향 자료 격리를 실제 요청으로 확인했습니다.

7. 제출 전 최종 점검

스스로 점검 항목	확인
공개 소개와 PRIVATE SPACE 가 화면에서 분리되어 있다.	✓
패스키 인증 전 실제 비공개 자료가 내려오지 않고 /api/private 가 401 로 거절된다.	✓
등록 challenge 를 서버에서 만들고 요청마다 새 값으로 발급한다.	✓
서버에는 공개키를 저장하고 등록 요청에 privateKey 원문이 포함되지 않는다.	✓
로그인마다 새 challenge 를 사용하고 저장 공개키로 서명을 검증한다.	✓
사용한 인증 challenge 를 재전송하면 AUTH_CHALLENGE_NOT_FOUND_OR_USED 로 거절된다.	✓
로그인 상태는 HttpOnly · Secure · SameSite=Lax 쿠키와 서버 세션으로 유지한다.	✓
한 계정에 패스키 2 개를 등록하고 하나를 삭제한 뒤 남은 패스키로 로그인했다.	✓
삭제한 패스키는 더 이상 인증에 사용할 수 없고 0 개 상황 안내도 구현했다.	✓
A/B 검증 계정은 서로 다른 비공개 자료를 가진다.	✓
상대 account ID 를 보내도 현재 로그인 세션의 자료만 반환되는 것을 양방향 확인했다.	✓
B 계정 자료는 DEMO-B 합성 데이터이며 실제 개인정보·비밀값을 넣지 않았다.	✓
제출 캡처에 비밀번호·세션 토큰·개인키 원문을 노출하지 않았다.	✓
패스키 구현 설명 6 개 항목과 확인 4 줄을 작성했다.	✓

제출용 요약

결과물 주소	https://08end.vercel.app/
소스 주소	https://github.com/rykim1217/ALEPH/tree/main/submit/task08
확인 4 줄	① 공개/비공개 경계와 401 차단 ② 공개키 저장·새 challenge·재사용 거절 ③ 패스키 2 개 등록·삭제·남은 패스키 로그인 ④ A/B 계정 양방향 비공개 자료 격리
공개 범위	PAGE 01·02 소개는 공개 · PAGE 03 실제 비공개 자료는 패스키 인증 후에만 서버에서 조회
검증 데이터	review-demo 는 과제 검증용 합성 계정이며 DEMO-B 합성 자료만 사용